

Análisis de Tráfico y Mitigación de Escaneos de Red

Resumen del Proyecto:

Simulación de una fase de reconocimiento (Footprinting) sobre un activo vulnerable (Metasploitable2) y su posterior detección mediante análisis forense de red con Wireshark. El proyecto demuestra la capacidad para identificar escaneos sigilosos (TCP SYN Stealth Scan), interpretar el comportamiento del stack TCP/IP y proponer medidas de mitigación alineadas con el Esquema Nacional de Seguridad (ENS) de España y la normativa ISO 27001.

Objetivo:

Detectar y analizar un escaneo de puertos mediante inspección de paquetes.

Metodología:

Para este caso se utilizó Wireshark capturando e inspeccionando el tráfico de red en tiempo real, enviando un nmap desde mi máquina Ubuntu a mi máquina Metasploitable.

```
oriana@oriana-VirtualBox:~$ sudo nmap -sS 192.168.56.101
[sudo] contraseña para oriana:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-24 14:56 CET
Nmap scan report for 192.168.56.101
Host is up (0.33s latency).
```

Análisis:

Durante el análisis de tráfico capturado, se identificaron múltiples intentos de conexión a un rango de puertos, destacando el puerto 50927 entre los puertos cerrados que respondieron con RST/ACK. De acuerdo al funcionamiento del protocolo TCP, esto confirma que dichos puertos estarían en estado "closed", ya que el host destino rechaza activamente la sincronización al no tener un servicio escuchando en esos sockets. También se puede determinar que se trata de un ataque realizado por una herramienta de escaneo automatizada y no un humano, ya que los intentos suceden casi al mismo tiempo.

Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda					
Aplique un filtro de visualización ... <Ctrl>->					
No.	Time	Source	Destination	Protocol	Length Info
102	64.331149724	192.168.56.102	192.168.56.101	TCP	58 50927 → 10626 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
103	64.335844870	192.168.56.102	192.168.56.101	TCP	58 50927 → 50000 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
104	64.336788180	192.168.56.102	192.168.56.101	TCP	58 50927 → 4998 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
105	64.337114305	192.168.56.102	192.168.56.101	TCP	58 50927 → 32782 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
106	64.337829360	192.168.56.102	192.168.56.101	TCP	58 50927 → 55600 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
107	64.338137382	192.168.56.102	192.168.56.101	TCP	58 50927 → 1875 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
108	64.338736304	192.168.56.102	192.168.56.101	TCP	58 50927 → 9502 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
109	64.339636322	192.168.56.102	192.168.56.101	TCP	58 50927 → 1234 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
110	64.340239447	192.168.56.101	192.168.56.102	TCP	60 19 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
111	64.340239860	192.168.56.101	192.168.56.102	TCP	60 5730 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
112	64.340239898	192.168.56.101	192.168.56.102	TCP	60 2967 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
113	64.340239918	192.168.56.101	192.168.56.102	TCP	60 711 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
114	64.341020161	192.168.56.101	192.168.56.102	TCP	60 10626 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
115	64.341020291	192.168.56.101	192.168.56.102	TCP	60 50000 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
116	64.341020311	192.168.56.101	192.168.56.102	TCP	60 4998 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
117	64.341020332	192.168.56.101	192.168.56.102	TCP	60 32782 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
118	64.341020362	192.168.56.101	192.168.56.102	TCP	60 55600 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
119	64.341020382	192.168.56.101	192.168.56.102	TCP	60 1875 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
120	64.341020402	192.168.56.101	192.168.56.102	TCP	60 9502 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
121	64.341020422	192.168.56.101	192.168.56.102	TCP	60 1234 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
122	64.341818798	192.168.56.102	192.168.56.101	TCP	58 50927 → 1864 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
123	64.342171782	192.168.56.102	192.168.56.101	TCP	58 50927 → 1271 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
124	64.342630128	192.168.56.101	192.168.56.102	TCP	60 1864 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
125	64.342891510	192.168.56.101	192.168.56.102	TCP	60 1271 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
126	64.346138649	192.168.56.102	192.168.56.101	TCP	58 50927 → 1078 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
127	64.346767076	192.168.56.102	192.168.56.101	TCP	58 50927 → 1090 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
128	64.347732688	192.168.56.101	192.168.56.102	TCP	60 1078 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
129	64.347732928	192.168.56.101	192.168.56.102	TCP	60 1090 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
130	64.348163944	192.168.56.102	192.168.56.101	TCP	58 50927 → 1198 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
131	64.349811050	192.168.56.101	192.168.56.102	TCP	60 1198 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
132	64.356776768	192.168.56.102	192.168.56.101	TCP	58 50927 → 1105 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
133	64.357784256	192.168.56.102	192.168.56.101	TCP	58 50927 → 32 [SYN] Seq=0 Win=1024 Len=0 MSS=1460

57	64.299268790	192.168.56.102	192.168.56.101	TCP	58 50927 → 80 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
58	64.299581521	192.168.56.102	192.168.56.101	TCP	58 50927 → 8888 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
59	64.300035789	192.168.56.101	192.168.56.102	TCP	60 80 → 50927 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
60	64.300036380	192.168.56.101	192.168.56.102	TCP	60 8888 → 50927 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
61	64.300052300	192.168.56.102	192.168.56.101	TCP	54 50927 → 80 [RST] Seq=1 Win=0 Len=0

**Handshake completo: En la segunda captura de wireshark, se puede ver un puerto abierto, respondiendo al primer intento de conexión de parte de ubuntu con un SYN/ACK y luego la máquina ubuntu cierra automáticamente la conexión enviando un RST para no dejar rastro en los logs de la aplicación. Lo llamado escaneo 'Stealth' o sigiloso.*

Recomendaciones de seguridad y mitigación:

Tras el análisis de tráfico y la identificación de puertos abiertos/cerrados en la máquina vulnerable (Metasploitable2), se proponen las siguientes medidas basadas en las prácticas de la ISO 27001 y el ENS (RD 311/2022):

1. **Aplicación del principio de mínimo privilegio.** Desactivar o desinstalar todos los servicios que no sean estrictamente necesarios para la función del servidor, así se conseguirá reducir la superficie de ataque ya que un puerto cerrado no puede ser explotado.
2. **Configuración de firewall perimetral.** Implementar reglas de firewall para que los puertos cerrados no respondan con un RST/ACK, sino que descarten el paquete. El atacante verá el puerto como "Filtered", al no recibir respuesta, el escaneo de nmap será mucho más lento y difícil de ejecutar, dificultando la fase de reconocimiento del atacante.

**Se intentó filtrar el puerto 80 en localhost para dejar el ejemplo, pero el stack TCP/IP de Ubuntu priorizo la comunicación interna sobre las*

reglas de UFW, resultando en un estado 'closed' (RST/ACK) en lugar de 'filtered'.

3. **Implementación de un IDS/IPS.** Instalar una herramienta como Suricata o Snort. Estos sistemas detectan patrones de escaneo de puertos (como la rafaga de paquetes SYN que se detectó en wireshark) y pueden bloquear automáticamente la IP del atacante o generar una alerta en tiempo real.